

R18

HTB · STARTING POINT

HTB Starting Point — Sequel

Programación para Ciberseguridad · Fase II · AD2026

MySQL es el sistema de gestión de bases de datos relacional más usado en aplicaciones web. Si el servidor MySQL está accesible desde la red sin contraseña para el usuario `root`, cualquiera puede conectarse, explorar todas las bases de datos y leer cualquier tabla — desde usuarios y contraseñas hasta datos de aplicaciones.

Objetivo: Conectarse al servidor MySQL sin credenciales usando el cliente `mysql` desde la terminal, enumerar las bases de datos disponibles y recuperar la flag.

Acceso a la plataforma

1. Inicia sesión en <https://app.hackthebox.com>, conecta la VPN de HTB.
2. Ve a Starting Point → Tier 1 → Sequel e inicia la máquina.
3. Anota la IP asignada.

Pistas de enfoque

Escanea con `nmap -sV <IP>` para identificar el puerto MySQL (3306). Conéctate con `mysql -h <IP> -u root` (sin contraseña — solo presiona Enter). Dentro del cliente MySQL, navega con los siguientes comandos:

```
SHOW DATABASES;  
USE <nombre_base_de_datos>;  
SHOW TABLES;  
SELECT * FROM <tabla>;
```

Evidencias requeridas

- Screenshot del escaneo de `nmap` con el puerto MySQL identificado.
- Screenshot de la conexión al servidor MySQL sin contraseña.
- Screenshot de la enumeración de bases de datos y tablas, con la flag visible.

Preguntas de reflexión

1. Compara esta máquina con Redeemer (R17): ambas exponen un sistema de base de datos sin autenticación. ¿En cuál de los dos sería más grave la exposición desde el punto de vista de confidencialidad, considerando el tipo de datos que cada sistema típicamente almacena?
2. `SELECT * FROM tabla` devuelve todos los registros. ¿Cómo modificarías la consulta para buscar solo los registros donde una columna llamada `rol` tenga el valor `'admin'`?
3. Un atacante que consigue acceso de escritura a un MySQL de producción podría hacer cosas peores que solo leer datos. ¿Qué dos acciones destructivas podría ejecutar y cuál sería el impacto de cada una?